

C4-diagrammen

OpenMRS LegacyUI Module — IN-B2.4 Security

Project	IN-B2.4 Security — Avans Hogeschool HBO-ICT
Module	legacyui-audit (OpenMRS Platform 2.0.0 + LegacyUI)
Datum	2026-06-05
Notatie	C4-model
Norm	NEN-7510:2024-2 — beveiligingsannotaties per container

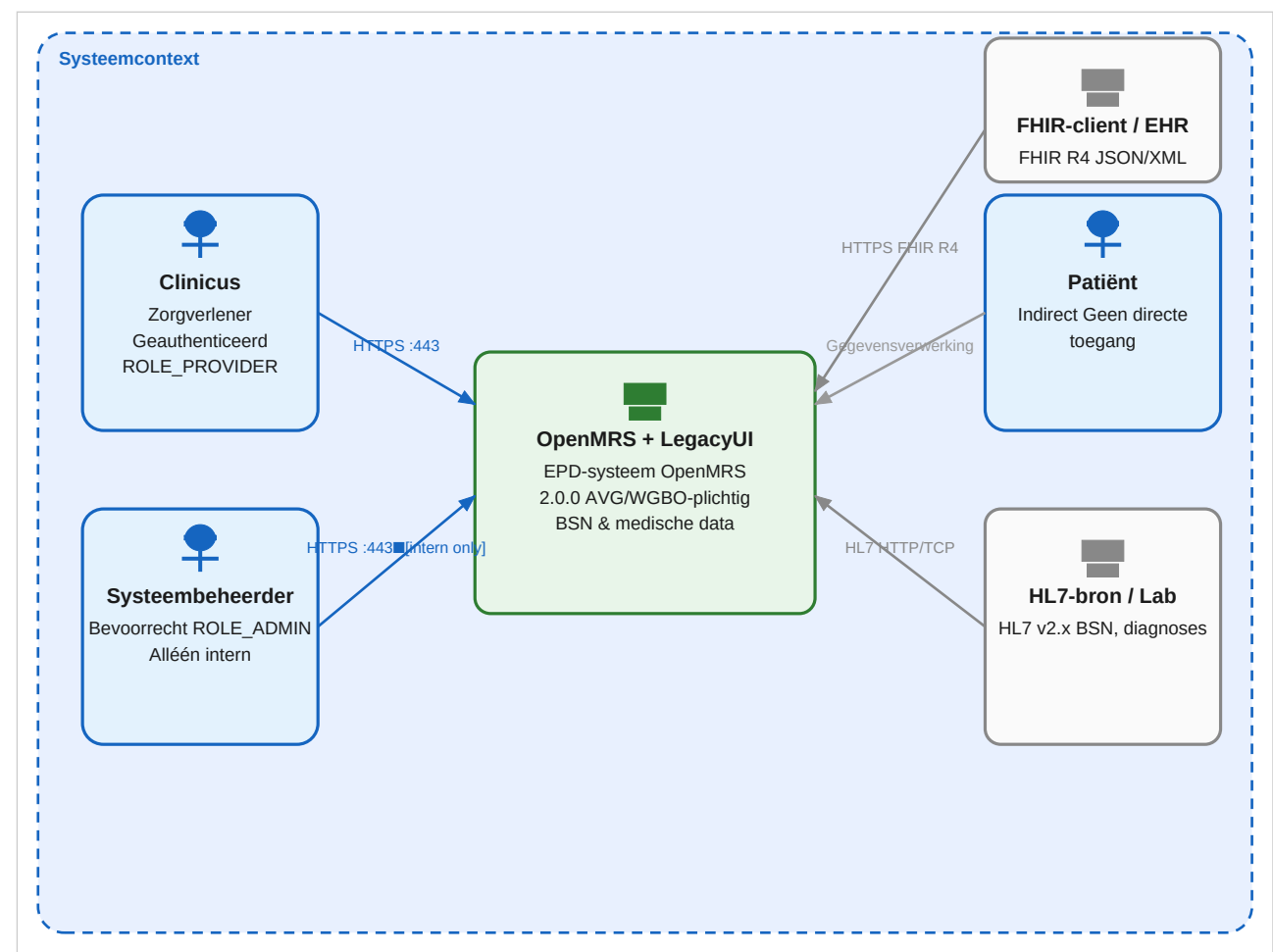
Dit document bevat de C4-diagrammen op niveau 0 (contextdiagram) en niveau 1 (containerdiagram) voor de OpenMRS LegacyUI-module. Beveiligingsannotaties zijn gekoppeld aan NEN-7510:2024-2 maatregelen. Opgesteld als onderdeel van WS02/WS03.

Legenda

Symbool	Betekenis	NEN-7510
Persoon (blauw)	Interne of externe gebruiker die met het systeem interacteert	—
Systeem (groen)	Het systeem zelf of een extern systeem	5.33, 8.2
Container (groen/rood)	Uitvoerbare eenheid: webserver, database, API	8.25
■ Rood kader	Kritieke beveiligingsgap aanwezig	8.25
Gestippelde grens	Vertrouwensgrens (trust boundary)	8.20
Pijl	Communicatierelatie met protocol	8.24

Niveau 0 — Contextdiagram (Systeemcontext)

Het contextdiagram toont het OpenMRS + LegacyUI-systeem als black box en alle externe actoren die ermee communiceren. Het definieert de grenzen van het systeem en wie er mee interacteert.



Figuur 1 — Niveau 0: Systeemcontextdiagram

Toelichting actoren

Actor	Type	Vertrouwensniveau	Beveiligingsoverwegingen
Clinicus	Intern persoon	Geauthenticeerd	Roltoewijzing vereist; toegang beperkt tot toegewezen patiënten
Systeembeheerder	Intern persoon	Geauthenticeerd + bevoorrecht	Admin-interface NOOIT publiek bereikbaar; elke actie auditloggen (NEN 8.16)
Patiënt	Extern (indirect)	Geen directe toegang	Bijzondere persoonsgegevens; AVG art. 9 + WGBO van toepassing
Externe HL7-bron	Extern systeem	Beperkt vertrouwd	HL7-invoer vereist validatie; berichten bevatten BSN en diagnoses
FHIR-client / EHR	Extern systeem	Beperkt vertrouwd	OAuth2/SMART-on-FHIR aanbevolen; dataminimalisatie toepassen (NEN 8.2)

Vertrouwensgrenzen contextdiagram

VERTROUWENSGRENS: Extern ↔ OpenMRS-systeem

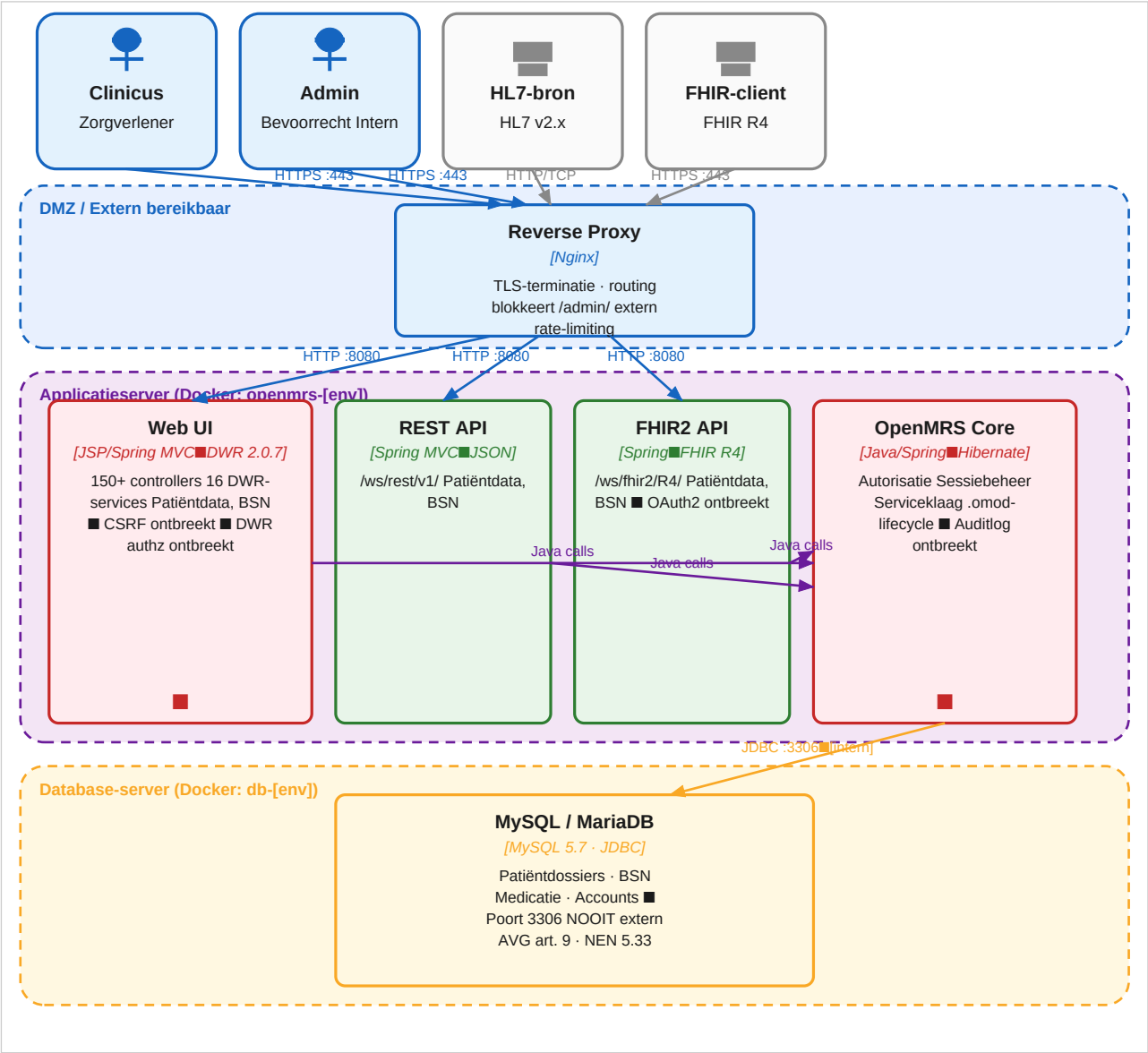
Alle externe actoren communiceren uitsluitend via HTTPS :443 door de Nginx reverse proxy.

Intern: /openmrs/admin/ geblokkeerd voor internet via Nginx ACL.

Intern: MySQL :3306 nooit extern bereikbaar (Docker intern netwerk).

Niveau 1 — Containerdiagram

Het containerdiagram toont alle containers (uitvoerbare eenheden/processen) binnen het OpenMRS + LegacyUI-systeem, hun verantwoordelijkheden, technologiestack en onderlinge communicatie. Containers met een rood kader hebben kritieke beveiligingsgaps.



Figuur 2 — Niveau 1: Containerdiagram

Toelichting per container

Container	Technologie	Verantwoordelijkheid	Beveiligingsstatus	NEN-7510
Reverse Proxy (Nginx)	Nginx	TLS-terminatie, routing, toegangsbepierking admin-area	■ Rate-limiting nog niet geconfigureerd	8.20, 8.21
Web UI (JSP/DWR)	JSP, Spring MVC, DWR 2.0.7	Legacy-webinterface voor clinici en beheerders	■ CSRF ontbreekt ■ DWR method-level authz ontbreekt	8.5, 8.25
REST API	Spring MVC, JSON	Programmatiese toegang voor externe clients	✓ Basis-authenticatie aanwezig	8.2, 8.25

Container	Technologie	Verantwoordelijkheid	Beveiligingsstatus	NEN-7510
FHIR2 API	Spring, FHIR R4, JSON/XML	Interoperabele patiëntdata-uitwisseling	■ OAuth2/SMART-on-FHIR niet geïmplementeerd	8.2, 8.24
OpenMRS Core	Java, Spring, Hibernate	Centrale businesslogica, autorisatie, modulebeheer	■ Auditlogging ontbreekt (risicoscore 20) ■ .omod-upload = RCE-risico	8.2, 8.5, 8.16, 8.25
MySQL / MariaDB	MySQL 5.7, JDBC	Persistentie van alle medische en persoonsgegevens	■ Data-at-rest encryptie niet bevestigd ■ Poort 3306 nooit extern	5.33, 8.24

Vertrouwensgrenzen containerdiagram

#	Grens	Controles / Gaps	NEN-7510
VG1	Internet ↔ Nginx	TLS verplicht (HTTPS-only) /openmrs/admin/ geblokkeerd voor extern verkeer Rate-limiting op /login en /forgotPasswordForm	8.5, 8.20
VG2	Nginx ↔ OpenMRS-applicatie	HTTP intern (Docker-netwerk) OpenMRS Core valideert sessie en privileges per verzoek CSRF-bescherming ontbreekt — kritieke gap (G1)	8.25
VG3	OpenMRS Core ↔ MySQL	Poort 3306 NOOIT extern blootgesteld Credentials via .env (niet in git) Data-at-rest encryptie aanbevolen	5.33, 8.24

Kritieke afhankelijkheidsketen:

DwrFilter → OpenmrsDWRServlet → [16 DWR-serviceklassen] → OpenMRS Core → MySQL
Geen CSRF-token, geen method-level autorisatie → hoogste aanvalsvlak van de module (NEN 8.25 gap G1/G4)

RCE-keten:

ModuleManagementController → ModuleFactory.loadModule() → JVM
Geen bestandstype-validatie → potentieel RCE bij kwaadaardig .omod (NEN 8.8, 8.25 kritieke gap G3)